Flag 12 of 18: Exfiltration URL

OAuth Heist scenario · Cymbal Investments · Google SecOps SIEM

Question

What is the full exfiltration URL (including destination IP and port) used by the attacker to transfer the compressed archive?

Answer

http://142.11.200.188:8888/upload/cymbal_q3_exfil.tar.zst

Evidence

Two events combine to give the full URL:

- **Sysmon network connection, 21:50:01Z.** `powershell.exe` (PID 6140) as `svc_dbadmin` on `CYM-DB-01` (`10.240.12.100`) connected to `142.11.200.188` on port `8888`. Tagged T1048 Exfiltration Over Alternative Protocol. The destination is a hosting provider (`hostpapa` , ASN 54290). Sysmon gives the IP and port, but no URL.
- **Zscaler proxy event, 21:50:21Z.** Method `POST` , response `200` , `sent_bytes` 485,120,000 (about 485 MB) against 400 bytes received. `target.url` is the full URL above.

A large outbound body with a tiny reply is the signature of an upload, and the file name matches the archive built by `zstd.exe` .

How it was found

Window: Oct 15 21:00 to 23:30 UTC. Earlier searches missed it because they filtered on `target.ip` only, while the proxy event stored the destination as a hostname and URL. The search that worked matched all three fields:

```
namespace = "Cymbal"
AND (re.regex(target.hostname, "142.11.200.188")
     OR re.regex(target.ip, "142.11.200.188")
     OR re.regex(target.url, "142.11.200.188"))
```

Lesson

The endpoint log shows who connected and where. The proxy log shows what was requested. For a full URL, go to the proxy event.

Next pivot

Check which other hosts contacted 142.11.200.188, and review the ransom note created on CYM-DB-01.